

Securing User Passwords

ANNE ADAMS AND MARTINA Angela Sasse say a lot of sensible things in their article about password selection, "Users Are Not the Enemy" (Dec. 1999, p. 41). They note correctly that users rarely know what is needed to construct a secure password and observe that "without feedback from security experts, users [create] their own rules on password design that [are] often anything but secure." They also note that within an organization, users may need several passwords in order to access multiple applications.

Alas, the authors don't mention how, specifically, to compose passwords that are both easy to remember and difficult to crack. There's lots of advice around about what *not* to do. Most informed users know, for example, that any word in the dictionary or an ordinary first name is a bad choice. What's lacking is specific, positive advice about good ways to create memorable, secure passwords that are part of the user culture. Lacking this advice, users—even computer professionals—resort to informed guessing as to what is and what is not secure.

For example, "password" is a poor choice. But how about "pazword," "pussword," "pass+word," "wordpass," "password8," and "PassWord"?

PAUL WATSON

The combinatorics of using simple variations on dictionary words would appear to be sufficient to defeat almost any guessing program, and many users rely on such variations (I often do).

A related problem is that almost everyone nowadays needs many, many passwords. ATM machines, Internet sites, and computer systems all demand them. What is a good strategy for dealing with this need? How dangerous is it to use the same password in unrelated contexts? How about constructing variant passwords by combining a base password with some standard information derived from the context in which the password is required? How should the strategy account for the specific and often incompatible requirements that particular applications may demand, such as ATM passwords mappable to a four-digit number on a telephone keypad, passwords at least six characters long, and passwords that include characters other than letters? And how should a strategy account for passwords that need to be changed regularly?

Ultimately, interactive biometrics is likely to become the standard replacement for passwords, because the strategies users must resort to in handling passwords have inherent risks.

Communications would do well to publish articles providing practical, positive advice on how to invent passwords for multiple contexts that minimize those risks.

PAUL ABRAHAMS
Deerfield, MA

"USERS ARE NOT THE ENEMY" contains many useful points on password security. I found myself in agreement with the authors. Security departments need to partner with users, rather than view them as the enemy within, and users need to better understand the threats to a company in a competitive environment.

Password discussions among academics often ignore the differences between Unix and IBM mainframe systems. This ignorance has the unintended consequence of driving security efforts to address the insecurities of a Unix environment in IBM mainframe environment.

In Unix and Unix-like systems, the password file is encrypted but stored publicly. This means crackers can download the file and on their own machine at high speed repeatedly try different passwords according to whatever scheme they choose. Dictionary words and ordinary names are quite vulnerable. For this reason, Unix users are advised to put extra characters in their passwords, including hyphens and numbers. This increases the length of the pass-

word list that needs to be tried and hopefully increases the system's security. Since users are allowed a large number of characters in their passwords, they can set up a phrase of common words with interspersed punctuation, backspaces, and so forth, thereby creating some very difficult-to-crack passwords.

The IBM mainframe world is different. The password file is not available publicly. This means that high-speed, off-line trials of passwords is prohibited. Furthermore, most systems shut down an account after three unsuccessful attempts to access it; so even a low-speed trial of passwords can be considered insufficient for cracking purposes.

However, appropriate security thinking for a Unix environment is typical, albeit inappropriate, in some IBM mainframe environments. These environments involve security packages that disallow dictionary words, force frequent changes, and disallow more than eight characters in each password, thereby forcing users to write down passwords in insecure places.

Had Unix thinking not driven policy, and had users been encouraged merely to use ordinary words not easily guessed, there would be less encouragement for users to write down their passwords.

In one IBM mainframe environment I observed, a curious situation arose as the security system sought to force users to change their passwords monthly. To enforce this policy, security had to keep a history of previous passwords. Security would keep a few old passwords on file so users did not reuse them. Some users changed passwords rapidly to exhaust the history list and cycle back to their favorite, easily remembered passwords. So security installed a feature that fits exactly into the "user as the enemy" thinking so eloquently stated in the article: users were not allowed to change passwords until 15 days had elapsed since their previous password change. Now, because users were the "enemy to be thwarted," a user, just after changing his or her password, then learning the new password, had been compromised, would be forced to do nothing and allow whomever had obtained the password to have access. The user certainly could not report this to the security department, because he or she would look unreliable or make the person suspected of obtaining the password appear suspicious—a very impolitic thing. This phenomenon is also present in those systems that make password changing difficult or impossible for the user.

Bill Patterson
Stratford, NJ

Combining OM and OG

In "Reexamining Organizational Memory" (Jan. 2000, p. 58) several observations are strikingly similar to issues resolved in the context of organizational genetics (OG).

Mark Ackerman and Christine Halverson note their interest is to "investigate where memory exists currently within an organization setting." They draw five conclusions: OM often involves distributed memory; memories may have mixed provenance; OM should be considered as "both object and process"; OM must carry "some marker of authenticity" to be useful; and context changes "are required to turn a memory 'object' into a memory process."

The authors also note early research "could consider memory as though it were a single, monolithic repository of some sort for the entire organization." They believe this to be an untenable position, observing, "This technical reconsideration has not been matched with a theoretical reconsideration."

OG supplies the needed theoretical context for independent support for their five conclusions (see "Applied Organizational Genetics," *Syst. Research*, Vol. 3, 1, 1986).

Briefly, OG demonstrates that the objects, structure, and derived processes of large enterprise databases are the functional equivalents of genetic material. This allows one to recognize and understand the organization in which they are embedded using many of the analytical tools of evolutionary biology and ecology. Without this foundation, the best one can do is argue by analogy to biological systems concerning how organizations behave. However, with OG, one has a demonstrable, empirically, and theoretically sound foundation on which to base subsequent observations, such as those of Ackerman and Halverson.

The evolution of OM is exactly the kind of mixed provenance phenomenon typical of systems built on genetic bases, serviced by multiple levels of organization, and responding to stimuli in determinant but context-sensitive ways. If Ackerman's and Halverson's work is retrofitted with an OG foundation, then their conclusions follow directly.

Anthony Fedanzo
Corte Madera, CA

Please address all Forum correspondence to the Editor, Communications, *1515 Broadway, New York, NY 10036; email: crawfordd@acm.org.*